Security Self-Assessment Report BambooLeaf

Defense-in-Depth and Risk Analysis for Guarded Autonomous Agent Wallets

Document Metadata

Item	Detail
Product	BambooLeaf
Assessed Snapshot	Post-Deployment & RBAC Release Candidate (Deployed Build)
Date	2026-10-19
Competition	2026 Shenzhen International FinTech Competition, International Track, Topic F (Agent Wallet)
Team	TEAM GLACIERS
Target Network	Ethereum Sepolia Testnet (Chain ID: 11155111)
Live Deployments	**Frontend**: https://bamboo-leaf.vercel.app/ **Backend API**: https://bambooleaf.onrender.com/
Companion Document	BambooLeaf: Technical Documentation

1. Scope, Methodology, and Assessment Baseline

This security self-assessment evaluates the BambooLeaf platform following its production deployment, role-based access control (RBAC) consolidation, and manual transaction portal implementation. The review combines static source inspection, local automated test suite execution, deployed HTTP and CORS evaluation, and adversarial prompt-injection screening within the isolated Attack Arena.

Verified Assessment Scope

- **Codebase & Integration Testing**:
  - Backend test suite: 93 passed, 0 failed.
  - LLM Planner test suite: 93 passed, 0 failed; TypeScript strict typecheck passed.
  - Frontend production build: Compiled without type or packaging errors.

- **Live Deployment Verification**:
  - Cross-Origin Resource Sharing (CORS) preflight resolution between Vercel and Render.
  - Web3 wallet-challenge signature onboarding and P-256 device registration.
  - Live Ethereum Sepolia execution (Chain ID: 11155111).
  - Multi-layer defense inspection via the interactive Attack Arena (/#/arena).

Explicit Non-Claims & Exclusions

This assessment was conducted entirely by the internal engineering team and does **not** constitute an independent third-party audit, formal cryptographic verification, or commercial regulatory certification (such as SOC 2, ISO 27001, or PCI DSS).
The system provides **bounded execution safety** exclusively for operations routed through its guarded API. It does not prevent direct abuse of the hot signer key if the underlying API server environment is compromised.

Terminology Convention
- Implemented: Functional source code exists and is deployed.
- Tested Locally: Automated unit or integration tests pass on this revision.
- Live Verified: Manually validated in active production environments.
- Tracked Gap: Identified residual risk or unexecuted formal benchmark.

2. Protected Assets and Trust Boundaries

2.1 Inventory of Protected Assets

1. **Agent Signing Key (AGENT_KEY) & Wallet Funds**: Hot private key loaded in server memory, funding live disbursements on Sepolia.
2. **Transaction Intent Parameters**: Execution metadata including target chain, recipient address, calldata payload, native value, and account nonce sequence.
3. **Supplier & Invoice Registry**: Normalized B2B vendor directory, verified recipient addresses, purchase-order balances, and invoice records.
4. **Identity & Device Sessions**: P-256 device public keys, signed session tokens, and cryptographic request proofs.
5. **Operational State & Audit History**: Operating autonomy levels ($L0$–$L3$), active policy limits, and SHA-256 hash-chained event records.

2.2 Trust Zones

Trust Zone	Environment & Technology	Invariants & Boundary Defense
1. Untrusted Zone	• Client Browser (React 19) • Web Crypto API (IndexedDB P-256 Key) • Public Internet / Direct User Input	Treated strictly as an untrusted environment. Every state-mutating request must generate an x-request-proof signature (timestamped and valid for ≤ 30 seconds).
2. External Model Zone	• Groq LLM Planner API • Dedicated Quarantine Endpoints • External Model Infrastructure	Isolated external boundary. Receives sanitized prompts and unvetted memos only; returns structured JSON output without tools, signing keys, or direct network execution permissions.
3. Trusted Application Zone	• Node.js / Express on Render • Device Authentication & RBAC Middleware • Quarantine Inspection Bridge • Deterministic Policy Guard • Backend Signer Module (AGENT_KEY)	The core enforcement boundary. Validates schemas, resolves grounded recipients, evaluates spending caps and autonomy tiers, and rechecks parameters immediately before signing.
4. Persistence Zone	• MongoDB Atlas	Secure data store holding verified supplier records, purchase orders, active device sessions, and the SHA-256 hash-chained audit ledger.

5. Execution Zone	• Ethereum Sepolia RPC Node • Target Chain ID: 11155111	Broadcasts raw, signed transactions received from the backend signer to the Sepolia testnet.

- **Core Architectural Boundary**: The frontend interface and external LLM providers are treated as untrusted. The enforcement boundary begins strictly at the Express middleware stack. Application policy only governs actions processed through the backend API; direct key compromise bypasses application safeguards.

3. Threat Model (STRIDE Analysis)

The system threat model accounts for malicious external attackers, prompt injectors, dishonest suppliers, and compromised administrative credentials:

Threat Category	Potential Attack Vector	System Vulnerability Surface	Implemented Countermeasure
Spoofing	Attacker impersonates an authorized user or forges API calls.	POST /api/goal and administrative mutation routes.	Wallet-challenge onboarding, P-256 browser key enrollment, and 30-second one-use request proofs.
Tampering	Supplier alters payout address on invoice or intercepts prompt.	Unstructured invoice text and prompt memos.	Destination loaded strictly from verified supplier registry; quarantine inspects memos; digest binds approval parameters.
Repudiation	Approver or admin denies authorizing a high-value transfer.	Payment execution and policy modification workflows.	Append-only SHA-256 hash-chained audit logging with sequence, timestamp, and request UUID

			tracking.
Information Disclosure	Unauthorized actors read wallet balances, suppliers, or logs.	Unprotected REST query endpoints.	Authenticated session requirements on audit, supplier, and balance endpoints.
Denial of Service	Flooding backend with adversarial prompts or rapid requests.	Public LLM planning and Attack Arena endpoints.	In-memory IP rate limiting on Attack Arena; bounded retry ceilings; velocity caps.
Elevation of Privilege	Clerk attempts to approve payments or reset autonomy levels.	Role-based administrative routes.	Server-side RBAC validation against MongoDB role store; maker-checker supplier activation rules.

4. Permission Tiers, Autonomy State Machine, and RBAC

4.1 Policy Tiers ($T1$ – $T3$)

The code strictly implements three execution tiers (Tier $T0$ is deprecated and does not exist in the active codebase):

- **T1 (Auto-Executable)**: Eligible for immediate, autonomous dispatch without manual intervention, provided the agent is operating at Autonomy Level $L2$ or $L3$ and all spending caps are satisfied.
- **T2 (Human Approval Required)**: High-value actions, newly registered targets, or actions triggered while operating in supervised Autonomy Level $L1$. Requires dual administrative sign-off within a 120-second expiration window.
- **T3 (Denied)**: Breaches hard velocity bounds, daily limits, allowlists, or is attempted while the agent is in $L0$. Execution halts immediately.

4.2 Autonomy Levels ($L0$ – $L3$)

AUTONOMY STATE TRANSITION RULES

L0: Frozen / Kill Switch Active

- All transaction execution halted; read-only operations permitted.
- Triggers: Critical violation, 3 blocked attempts in 10m, or Kill Switch.
- Recovery: Requires authenticated Admin manual reset (returns to L1).

L1: Restricted / Supervised Execution
- Every valid transaction routes to Tier 2 (human approval required).
- Progression: Requires 10 consecutive clean executions to promote to L2.

L2: Standard Guarded Autonomy
- T1 actions auto-execute within standard caps; T2 requires approval.
- Demotion: Blocked attempts drop the system back toward L1 or L0.

L3: High / Trusted Autonomy
- Extended operational velocity, strictly bounded by policy engine limits.

- **Dynamic Risk Score Note**: While an experimental computeRiskScore helper exists in the repository, live transaction pathways currently default riskScore = 0. Routing decisions depend strictly on deterministic spending caps, allowlists, and autonomy states.

4.3 Consolidated RBAC & Separation of Duties

User roles are assigned by an Admin after Web3 wallet connection:

Role	Operational Scope & Permissions DOCX	Enforcement Invariants DOCX
Admin	Manages suppliers, purchase orders, role assignments, policy edits, device reviews, kill switches, and approval tickets.	Cannot modify, truncate, or delete historical audit records.
Approver	Authorizes pending Tier 2 payment tickets, verifies new suppliers, and reads system logs and policy.	Cannot alter policy limits, reassign roles, or approve their own supplier registrations.
Clerk	Submits natural-language goals, transacts via manual fallback, and ingests structured invoices.	Cannot approve disbursements, alter policy, or inspect audit consoles.
Auditor	Inspects compliance	Read-only access; cannot

	consoles, verifies audit hash linkages, and exports CSV/JSON logs.	submit payments, sign tickets, or mutate state.

- **Maker-Checker Invariant**: A supplier created by an administrator cannot be activated by that same individual; a separate administrator or approver must review and activate the record before it becomes eligible for payouts.

5. Defense-in-Depth Layered Control Matrix

BambooLeaf enforces security across seven distinct functional layers:

1. Quarantine Boundary: Screens untrusted memo text for prompt injections.
2. Planner Validation: Strict Zod schema enforcement; temperature 0.
3. Recipient Grounding: Resolves destinations from internal registry only.
4. Deterministic Guard: Hard spending caps, velocity windows, and daily quotas.
5. Human Approval Ticket:120-second TTL digest binding all parameters.
6. Signer Re-Check: Verifies chain ID, balance ceiling, nonce, and kill state.
7. Audit Chain: Immutable SHA-256 hash linkage of all operational events.

Detailed Layer Controls

1. **Input Sanitization & Quarantine**: Structured schema validation on intake. Unstructured memos and external texts pass to an isolated classifier that fails closed upon detecting prompt injections or experiencing API timeouts.
2. **Planner Grounding Bridge**: Restricts LLM responses to a rigid JSON object. Recipient names are translated into addresses strictly via the internal address book; raw addresses cannot be inferred by the model.
3. **Deterministic Policy Engine**: Enforces operational ceilings on Sepolia: maximum 0.02 ETH per transaction, 0.05 ETH daily recipient cap, and maximum 5 operations per 600-second window.
4. **Shadow-Fork Swap Simulator**: Simulates ERC-20 token exchanges on a local fork, evaluating balance changes and approval traces against the original intent before signing.
5. **Cryptographic Approval Queue**: Tier 2 actions produce a Keccak-256 digest ticket expiring in 120 seconds. The approver's wallet must match an active session with Approver or Admin privileges.
6. **Isolated Backend Signer**: Operates as a distinct software boundary holding AGENT_KEY. Rechecks chain ID, account nonce, spending limits, and kill-switch status immediately before broadcasting.
7. **Tamper-Evident Ledger**: Events are linked using SHA-256 hashes, enabling on-demand detection of record modification or deletion.

6. Controls-to-Threats Traceability Matrix

Threat Description	Layered Control Implementation	Verification Method & Artifact	Status
Indirect Prompt Injection	Quarantine classifier screens text; planner isolated from signing tools.	Attack Arena tests (/#/arena); quarantine evaluation logs.	Implemented & Verified
Hallucinated Recipient Address	Strict Zod validation and address-book grounding.	Planner unit tests; invalid recipient rejection tests.	Implemented & Tested
Unauthorized Fund Transfer	Recipient allowlisting, transaction caps, velocity limits.	Policy engine unit tests; live Sepolia execution checks.	Implemented & Tested
Approval Replay / Alteration	Keccak-256 digest ticket, 120s TTL, single-use claim tracking.	Digest validation tests; live Approval Queue (/#/approvals).	Implemented & Tested
Duplicate / Tampered Invoice	Unique (Supplier, Invoice#) index; PO limit validation.	Invoice escalation tests (et3ef PO mismatch).	Implemented & Verified
Audit Ledger Modification	SHA-256 hash chaining over sequential event payloads.	Compliance Console verification (/api/audit/verify).	Implemented & Tested
Replayed API / Device Proof	30-second timestamped P-256 signature bound to request body.	Middleware authentication tests; device security console.	Implemented & Tested

7. Red-Team and Adversarial Evaluations

Empirical testing evaluates the LLM planner and deterministic guards under isolated conditions:

Evaluation Suite	Sample Size & Method	Measured Results	Catching Layer & Operational Caveats
Live Planner Evaluation	68 requests (Groq llama-3.3-70b-versatile).	64/64 valid JSON schemas; 22/22 legitimate passes; 0/22 false positives; 6/41 planner-level false negatives (14.6%).	**Planner Layer Only**: Harmful proposals that bypass the planner are subsequently intercepted by the policy engine.
Offline Guard Replay	45 adversarial test runs against the policy guard.	0/45 harmful executions dispatched; 8/8 harmful planner outputs held ($T2$) or denied ($T3$).	**Policy Layer**: Validates deterministic off-chain limits under simulated provider failures.
Quarantine Model Test	13 evaluation payloads (9 injected, 4 benign).	9/9 malicious injections flagged; 0/9 address leaks; 0/4 benign false positives.	**Quarantine Layer**: Heuristic classification; non-independent evaluation set.
Attack Arena Presets	Interactive adversarial console (/#/arena).	Evaluates prompt injections, jailbreaks, and over-limit attacks in Guarded vs. Naive modes.	**Sandbox Boundary**: Signer isolated; dispatches 0 live transactions by design.

8. Operational Security and Deployment Baseline

- **Key Management**: The hot signing key (AGENT_KEY) is stored as an environment variable within the Render API container. The key is never exposed to client browsers, transmission payloads, or third-party LLMs.
- **Disbursement Safety Limits**: Operational risk is constrained by funding minimal balances on the signing address (0.1680 ETH), coupled with backend daily caps (0.05 ETH).
- **Emergency Offboarding**: Administrators can trigger the **Emergency Kill Switch** from the Autonomy console to freeze the platform to $L0$, revoke device credentials, and clear active sessions.

9. Compliance, Records, and Privacy

- **Audit Retention & Verification**: System events record a sequence ID, timestamp, request UUID, canonical data hash, previous hash, and current SHA-256 hash. The Compliance Console (/#/compliance) supports integrity verification and CSV/JSON export.
- **Data Processing & Privacy**:
  - Goal prompts are evaluated by the external LLM planner (Groq).
  - Raw invoice memos pass to the quarantine provider for injection screening.
  - Destination addresses are resolved internally; third-party model providers receive aliases rather than private address registries.
  - Production deployments should formalize explicit data-processing and retention agreements with external model providers.

10. Comprehensive Known-Risk Register

ID	Vulnerability Domain	Identified Risk Scenario	Initial Risk	Existing Mitigations	Residual Risk & Planned Roadmap
KR-01	Key Management	Host compromise exposes the hot AGENT_KEY.	**High**	Policy spending caps, low wallet balances (0.1680 ETH).	**Medium**: Migrate to smart-contract account abstraction (ERC-4337) with on-chain limits.
KR-02	Blockchain	Stolen private key used directly on-chain.	**High**	Off-chain policy limits backend-initiated calls.	**High**: Pure off-chain policy cannot prevent external key abuse;

					requires contract-level controls.
KR-03	Model Safety	Quarantine classifier misses a novel injection.	**Medium**	Deterministic address grounding and strict Zod schemas.	**Low**: Malicious model proposals are rejected by deterministic policy guards.
KR-04	Availability	External LLM or RPC node outage halts payments.	**Medium**	System fails closed; manual fallback portal (/#/transact).	**Low**: Fallback portal permits manual policy-guarded payments during model outages.
KR-05	Audit Security	Database operator alters or recalculates audit logs.	**Medium**	Cryptographic SHA-256 hash chaining with verification API.	**Medium**: Hash chain lives in MongoDB; requires external anchoring to public L1/L2 networks.
KR-06	Data Privacy	Goal prompts expose internal business memos.	**Medium**	Quarantine summary sanitization; alias grounding.	**Low**: Formalize commercial zero-data-retention terms with LLM infrastructure

					providers.
KR-07	Empirical Testing	Lack of third-party adversarial red-team benchmarks.	**Medium**	186 unit/integration tests; Attack Arena testbed.	**Medium**: Complete repeated end-to-end benchmark runs across varied attack vectors.
KR-08	Client Security	Browser XSS compromises active session token.	**Medium**	P-256 keys non-extractable in IndexedDB; 30s request proofs.	**Low**: Compromised sessions cannot export private keys; require hardware-backed passkeys.
KR-09	Endpoint Access	Unauthenticated access to wallet balance.	**Low**	Authenticated session requirements applied to balance routes.	**Resolved**: Route protected by session verification middleware.

11. Residual-Risk Statement

BambooLeaf enforces defense-in-depth across transactions routed through its guarded backend API. The platform bounds potential financial loss through off-chain allowlisting, per-transaction and velocity limits, minimal wallet funding, and human-in-the-loop approvals for anomalous transactions.

Explicit Security Boundaries:

- The system does **not** protect against on-chain transactions initiated outside the backend API using a compromised private key.
- The system does **not** guarantee immutable audit logging against a compromised database administrator with full write access to MongoDB.
- Heuristic prompt-quarantine layers reduce injection risk but remain probabilistic;

deterministic policy checks serve as the primary enforcement boundary.
This assessment does not describe BambooLeaf as invulnerable, but establishes that its layered architecture prevents unconstrained execution by an LLM.

12. Security Verification & Ongoing Hardening Roadmap

Verified Operational Status

1. **Manual Fallback Integration**: Manual transaction portal (/#/transact) deployed, providing a policy-guarded alternative during AI provider downtime.
2. **Access Control Hardening**: Web3 wallet sign-in, administrative device approval, and P-256 request proofs active across all state-mutating endpoints.
3. **Endpoint Protection**: Middleware authentication enforced across operational routes, resolving historical balance exposure risks.
4. **Adversarial Sandbox**: Attack Arena operational with complete signer isolation.

Ongoing Hardening Priorities

- **On-Chain Policy Enforcement**: Transitioning spending limits from off-chain middleware to smart-contract account abstraction (ERC-4337) to prevent unauthorized transactions even if private keys are exposed.
- **WebAuthn / Hardware Passkeys**: Migrating device keys from browser IndexedDB storage to hardware-backed secure enclaves (TouchID/YubiKey).
- **Decentralized Audit Commitments**: Periodically publishing audit ledger state roots to an on-chain smart contract for immutable third-party verification.
- **Independent External Red-Teaming**: Conducting third-party penetration testing and formal adversarial evaluations on smart-contract and LLM integration layers.